TraceBack — Defects Found and Fixed

Nov 6, 2026 · @Soumyaranjan

Deliverable 3 testing found 25 defects and weaknesses in TraceBack: 1 critical, 6 high, 12 medium and 6 low. All 25 are fixed, each fix is re-checked by the test, attack or audit that exposed it, and every suite passes on the final code. None of them broke sign-in, access control or the claim rules under normal use; they surfaced under load, under parallel requests, under attack, in failures, and in peer review.

TraceBack is the IIT Kanpur Lost & Found portal. This register is the defect history for Deliverable 3; IDs (D-01 to D-25) are used across the test reports. The team's Jira site is suspended, so the history is kept here and in the commit messages on the `d3/integration` branch.

Where the defects came from

Found by	Critical	High	Medium	Low	Total
Load test (Performance report)	1	1	1	2	5
Concurrency tests	–	3	3	1	7
Adversarial tests and library audits	–	1	3	2	6
Failure and recovery tests	–	1	3	–	4
Deliverable 2 peer reviews	–	–	2	1	3
All	**1**	**6**	**12**	**6**	**25**

Defect register

ID	Severity	Defect	Found by	Fix (commit on `d3/integration`)	Verified by	Status
D-01	Critical	The API locked up at 25 simultaneous users: 40 worker threads waited for 15 database connections while the requests holding them waited for a thread; nothing was answered until 30-second timeouts	Load test (ramp), CON-14	At most 30 requests in flight per process; pool sized to match (`423b3bf`)	Ramp test: 0 errors up to 100 users; CON-14	Fixed

ID	Severity	Defect	Found by	Fix (commit on `d3/integration`)	Verified by	Status
D-02	High	Two guards could hand over the same item at once: 2 “collected” entries in 10 of 10 trials	CON-08	Item row, then claim row locked in every claim action (`c2b51ad`)	CON-08: 1 hand-over in 40 of 40	Fixed
D-03	High	One guard approving while another rejected the same claim recorded both decisions (2 of 10 trials)	CON-07	Same row locks (`c2b51ad`)	CON-07: 1 decision in 40 of 40	Fixed
D-04	High	A claimant withdrawing during hand-over left claim and item disagreeing (6 of 10 trials)	CON-09	Same row locks (`c2b51ad`)	CON-09: history consistent in 40 of 40	Fixed
D-05	Medium	Two guards could receive the same item at two offices: 2 receipts in 10 of 10 trials	CON-04	Item row locked in receive, transfer and dispose (`c2b51ad`)	CON-04: 1 receipt in 40 of 40	Fixed
D-06	Medium	10 parallel sign-in requests for one address sent up to 7 codes, skipping the 60-second wait	CON-01	Per-address advisory lock (`c2b51ad`)	CON-01: 1 code, 9 “please wait”	Fixed
D-07	Low	Sending the same claim 5 times at once gave 500 errors (30 of 50 responses)	CON-05	Duplicate caught by the database answered 409 (`c2b51ad`)	CON-05: 0 server errors	Fixed
D-08	Medium	A 136 KB image of 12,000 × 12,000 pixels needed 782 MB to decode	ADV-18	Images over 60 megapixels refused before decoding (`423b3bf`)	ADV-18 stopped (400); `test_performance_changes.py`	Fixed
D-09	High	List pages sent full-size 2.9 MB photos: 18–21 MB per page view, 99.97% of the bytes	Load test	640 px WebP thumbnails for lists (`423b3bf`)	0.7–1.0 MB per page view	Fixed
D-10	Medium	Photo and proof uploads ran on the shared event loop and blocked every other request	Load test (profiler)	Upload endpoints run in worker threads (`423b3bf`)	Ramp and campus tests	Fixed
D-11	High	Next.js 16.4.0 had 3 published advisories (2 critical)	ADV-24 (`npm audit`)	Upgraded to 16.4.5 (`0e64287`)	`npm audit`: 0 vulnerabilities	Fixed

ID	Severity	Defect	Found by	Fix (commit on `d3/integration`)	Verified by	Status
D-12	Medium	Pillow 12.3.0, which decodes every upload, had 39 published advisories	ADV-25 (`pip-audit`)	Upgraded to 13.0.0 with fastembed 0.9.1 (`0e64287`)	`pip-audit`: none found	Fixed
D-13	Medium	Shared photos kept their GPS location (EXIF)	ADV-17	Metadata removed on upload, picture unchanged (`a541035`)	ADV-17 stopped; `test_hardening.py`	Fixed
D-14	Low	No security headers (nosniff, frame protection, Referrer-Policy); X-Powered-By sent	ADV-16, ADV-19	Headers in Next.js, FastAPI and Caddy (`a541035`)	ADV-16, ADV-19 stopped	Fixed
D-15	Low	API documentation public in production	ADV-21	`API_DOCS=false` on the server (`a541035`)	ADV-21: 404	Fixed
D-16	Medium	Seeded office text “PLACEHOLDER: update with real directions” reached a student in an email (FND-0740)	D2 review of PR #19	No seeded directions; old text cleared; emails omit missing directions; `set-office` command (`a9aba2b`)	`test_hardening.py` (5 tests)	Fixed
D-17	Medium	Failed emails were never retried	D2 review of PR #20	Temporary SMTP failures retried twice, 2 s then 4 s (`a9aba2b`)	`test_hardening.py`; FR-08	Fixed
D-18	Low	The AI agent’s limits were hard-coded constants	D2 review of PR #15	Moved to settings (`AGENT_*`) (`a9aba2b`)	`test_hardening.py`	Fixed
D-19	Medium	With the database down, requests got a bare 500 and some connections were dropped	FR-01	Clear 503 with Retry-After (`9fd794f`)	FR-01, FR-02	Fixed
D-20	Medium	A crash between saving a report and queueing its AI job left a report never analysed	FR-04	Report and job in one commit (`9fd794f`)	FR-04: 0 of 336 without a job	Fixed
D-21	High	An AI job interrupted by a killed worker failed for good; the page said “looking for matches” forever	FR-06	Interrupted jobs re-run, up to 3 tries (`9fd794f`, migration `7f3a2c9d41b8`)	FR-06: done 0.9 s after restart	Fixed
D-22	Medium	A sign-in code that could not be emailed blocked a retry for 60 s	FR-08	Unsent code removed (`9fd794f`)	FR-08: immediate retry 202	Fixed

ID	Severity	Defect	Found by	Fix (commit on `d3/integration`)	Verified by	Status
D-23	Low	Extra database queries: 2 per signed-in request, 5 per photo, 21 for the staff claims page	Load test (query counter)	1, 2 and 9 queries (`423b3bf`)	`test_performance_changes.py`	Fixed
D-24	Low	The AI queue also ran inside the API, loading the AI model twice	Load test (configuration)	AI queue only in the worker container (`423b3bf`)	Deployment configuration	Fixed
D-25	Medium	Once uploads moved to threads, 6 parallel uploads could pass the 3-photo limit	CON-10 (during the D-10 fix)	Item row locked while photos are counted (`423b3bf`)	CON-10: 3 stored in 40 of 40	Fixed

Evidence for six significant defects

D-01 — the API locked up under load (critical)

- **Found:** in the ramp test, not one request succeeded at 25, 50 or 100 simultaneous users, and with normal pauses 99.4–100% failed from 50 to 400 users. The API's CPU fell to about 1%: it was waiting, not working.
- **Cause:** the profiler (py-spy) showed all 40 FastAPI worker threads waiting for one of 15 database connections, while the requests holding those connections waited for a thread for their next step.
- **Fix:** a small ASGI middleware (`core/capacity.py`) lets at most 30 requests work at once per process, with a pool connection for each; the rest wait without holding anything and get 503 after 20 s.
- **Verified:** 100 users flat out with 0 errors at 231–255 requests a second; 200 users browsing with 95% of requests under 0.85 s; CON-14 passes (Performance report).

D-03 — approve and reject recorded together (high)

- **Found:** CON-07 sent "approve" and "reject" for the same claim at the same instant; in 2 of 10 trials both were recorded, leaving the claim's history contradicting its status.
- **Cause:** each action read the claim, checked its status and wrote, without locking; two requests could both pass the check.
- **Fix:** every claim action locks the item row and then the claim row, always in that order (no deadlocks), and reads both again before checking the rules (`services/claims.py`, `_lock`). The same fix closed D-02, D-04 and D-05.

- **Verified:** CON-04 to CON-09 pass in 40 of 40 trials each, with no deadlock in the PostgreSQL log.

D-13 — GPS location in shared photos (medium)

- **Found:** ADV-17 uploaded a phone photo with GPS data; another student downloaded it with the location intact. Found items are photographed where they were found, often in hostels.
- **Fix:** `storage.strip_metadata` removes EXIF, XMP and IPTC data on upload. JPEGs are cleaned segment by segment without re-encoding, so the picture is byte-identical and only the rotation flag is kept; PNG and WebP are re-saved. A damaged photo that still carries metadata is refused rather than shared.
- **Verified:** ADV-17 stopped; 10 tests in `test_hardening.py` (GPS gone, pixels identical, rotation kept, damaged files refused).

D-21 — interrupted AI jobs never finished (high)

- **Found:** FR-06 killed the worker while it held an AI job. After the restart the job was marked “failed”, the report never got matches, and its page showed “looking for matches” indefinitely.
- **Cause:** interrupted jobs were failed outright, judged by when they were queued rather than started.
- **Fix:** a `started_at` column (migration `7f3a2c9d41b8`); jobs running longer than 10 minutes are queued again, up to 3 tries, and after that the page says matching failed.
- **Verified:** FR-06 passes, finishing 0.9 s after the worker restarts; 5 tests in `test_failure_recovery.py`.

D-16 — placeholder text in a real email (medium)

- **Found:** in the Deliverable 2 review of PR #19, a teammate showed an owner email (FND-0740) that told the student to go to “PLACEHOLDER: update with real directions”.
- **Fix:** the seed no longer invents directions and clears old placeholder text on every start; emails and pages leave out directions that aren’t set; `python -m app.cli set-office` records the real ones.
- **Verified:** 5 tests in `test_hardening.py`, including an approval email with placeholder data in the database.

D-11 — a framework version with critical advisories (high)

- **Found:** `npm audit` (ADV-24) reported 3 advisories against Next.js 16.4.0, 2 of them critical (image optimisation, caching and Server Actions).
- **Fix:** upgraded to 16.4.5, a patch release; Pillow was upgraded at the same time (D-12).
- **Verified:** `npm audit` and `pip-audit` report nothing; the production build, the 15 system tests and the 23 attacks pass on the new versions.

Regression protection

Each fix is checked again on every run by the test, attack or audit that first exposed the problem: the concurrency and failure suites reproduce the races and crashes, the adversarial script repeats the attacks, and 35 pytest tests (`test_hardening.py` , `test_failure_recovery.py`) pin the security and recovery fixes. The full pytest suite (459 tests) runs in about 26 seconds.